

API SECURITY RISK ANALYSIS REPORT

Security Analysis of API Vulnerabilities



Name : H.Maruthi Raj

Internship: Cyber Security Internship (Future Interns)

Date: April 2026

TABLE OF CONTENTS

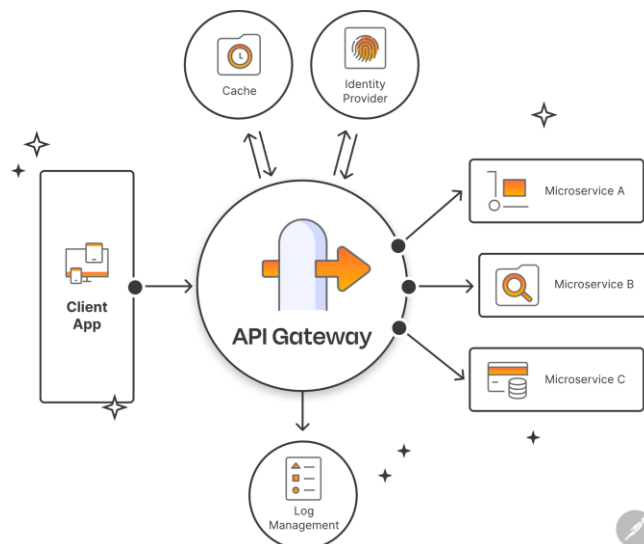
1. Executive Summary	3
2. Introduction	4
3. API Overview	5
4. API Security Risks	6 - 11
4.1 Broken Authentication	6
4.2 Broken Authorization	7
4.3 Excessive Data Exposure	8
4.4 Lack of Input Validation	9
4.5 Lack of Rate Limiting	10
4.6 Security Misconfiguration	11
5. Risk Summary	12
6. Security Recommendations	13
7. Conclusion	14

Executive Summary :

- This report presents an analysis of security risks associated with Application Programming Interfaces (APIs).
- The objective of this assessment is to identify common API security vulnerabilities such as improper authentication, data exposure, and lack of input validation.
- The analysis highlights potential risks that can arise when APIs are not properly secured, including unauthorized access, data leakage, and misuse of services.
- This report also provides recommendations to improve API security and ensure safe data communication between systems.

Introduction

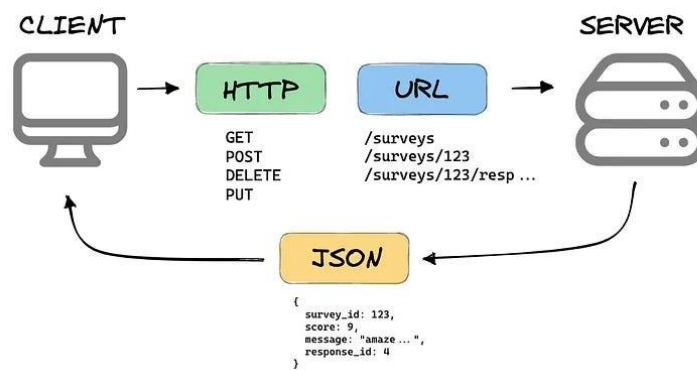
- An Application Programming Interface (API) is a set of rules that allows different software applications to communicate with each other.
- APIs are widely used in modern applications to enable data exchange between systems such as web applications, mobile apps, and cloud services.
- However, if APIs are not properly secured, they can become a major point of attack for cybercriminals. Attackers can exploit vulnerabilities in APIs to gain unauthorized access, steal sensitive data, or disrupt services.
- API security focuses on protecting data, ensuring proper authentication and authorization, and preventing misuse of API endpoints.
- Understanding common API vulnerabilities is essential for building secure and reliable systems.



API Overview

- An API acts as an intermediary that allows different applications to communicate with each other by sending and receiving requests.
- When a user interacts with an application, a request is sent to the API. The API processes the request, communicates with the server or database, and returns a response to the user.
- APIs commonly use HTTP methods such as GET, POST, PUT, and DELETE to perform operations like retrieving, creating, updating, and deleting data.
- For example, when a user logs into a website, the application sends the login credentials to the API, which verifies the information and returns a response indicating whether the login is successful.
- Proper API design and security are essential to ensure that only authorized users can access data and services.

WHAT IS A REST API?



API Security Risks

1. Broken Authentication

➤ **Description :**

Broken authentication occurs when an API does not properly verify the identity of users. Weak authentication mechanisms allow attackers to bypass login controls and gain unauthorized access.

➤ **Impact :**

Attackers can access user accounts, steal sensitive data, or perform actions on behalf of legitimate users.

➤ **Risk Level :** High

➤ **Recommendation:**

- Implement strong authentication mechanisms
- Use secure tokens (JWT, OAuth)
 - Enforce password policies and session management



2. Broken Authorization

➤ Description :

Broken authorization occurs when an API fails to properly restrict user access to resources. Users may access data or perform actions beyond their permissions.

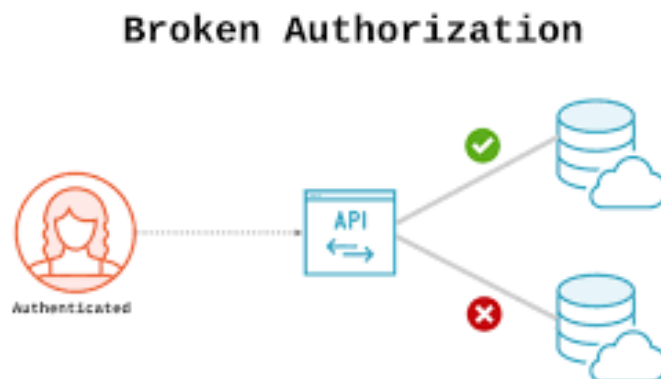
➤ Impact :

Unauthorized users can access sensitive data or modify resources they should not have access to.

➤ Risk Level : High

➤ Recommendation :

- Implement proper role-based access control (RBAC)
- Validate user permissions on every request
- Avoid exposing sensitive endpoints



3. Excessive Data Exposure

➤ Description :

Excessive data exposure occurs when an API returns more data than necessary in its response. Sensitive information such as user details or internal data may be exposed unintentionally.

➤ Impact :

Attackers can collect sensitive data and use it for malicious purposes such as identity theft or further attacks.

➤ Risk Level : High

➤ Recommendation :

- Return only required data in API responses
- Filter sensitive information
- Implement proper data access controls



4. Lack of Input Validation

➤ Description :

APIs that do not properly validate user input are vulnerable to attacks such as injection, malicious data submission, and unexpected behavior.

➤ Impact :

Attackers can manipulate inputs to exploit the system, potentially leading to data corruption or system compromise.

➤ Risk Level : High

➤ Recommendation:

- Validate and sanitize all user inputs
- Use strict data formats and validation rules
- Reject unexpected or malicious input



5. Lack of Rate Limiting

➤ Description:

Lack of rate limiting occurs when an API does not restrict the number of requests a user can make within a specific time period. This allows attackers to send a large number of requests to the API.

➤ Impact:

Attackers can perform brute force attacks, overload the server, or cause denial-of-service (DoS) conditions.

➤ Risk Level : Medium

➤ Recommendation:

- Implement rate limiting to control request frequency
- Monitor traffic for unusual activity
- Block suspicious IP addresses



6. Security Misconfiguration

➤ Description :

Security misconfiguration occurs when APIs are not properly configured, leaving unnecessary features or sensitive information exposed.

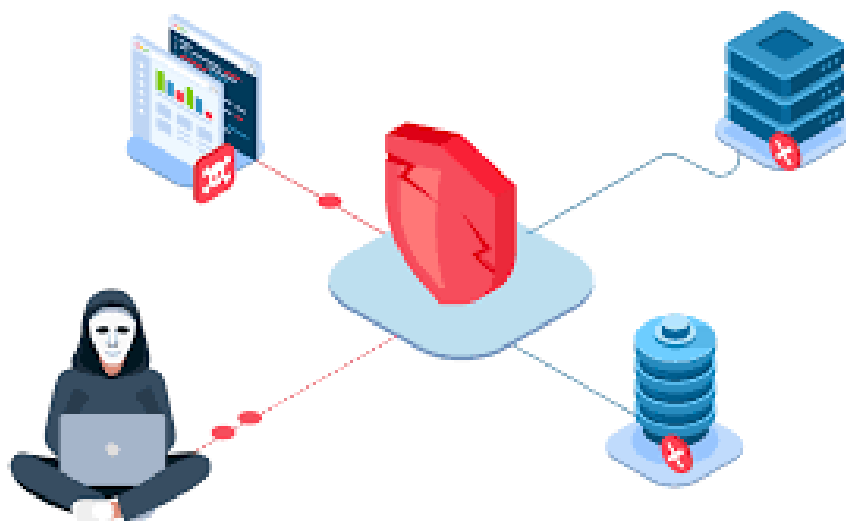
➤ Impact:

Attackers can exploit misconfigured settings to gain access to sensitive data or system functionality.

➤ Risk Level : Medium

➤ Recommendation:

- Disable unnecessary features and endpoints
- Use secure configuration settings
- Regularly review and update security configurations



Risk Summary

The following table summarizes the API security risks identified along with their impact and severity levels.

Risk	Risk Level	Impact	Recommendation
Broken Authentication	High	Unauthorized access to accounts	Use strong authentication and secure tokens
Broken Authorization	High	Access to restricted data	Implement role-based access control
Excessive Data Exposure	High	Leakage of sensitive data	Return only necessary data
Lack of Input Validation	High	System manipulation and attacks	Validate and sanitize inputs
Lack of Rate Limiting	Medium	Server overload and brute force	Limit number of requests
Security Misconfiguration	Medium	Exposure of system vulnerabilities	Use secure configurations

Security Recommendations

To improve API security and prevent potential attacks, the following recommendations should be implemented:

1. Implement Strong Authentication:

Use secure authentication methods such as OAuth or JWT tokens to verify user identity.

2. Enforce Proper Authorization:

Ensure that users can only access resources based on their roles and permissions.

3. Minimize Data Exposure:

Return only necessary data in API responses and avoid exposing sensitive information.

4. Validate User Input:

Apply strict input validation to prevent injection attacks and malicious data entry.

5. Enable Rate Limiting:

Restrict the number of API requests to prevent abuse and brute force attacks.

6. Use Secure Communication:

Ensure all API communication is encrypted using HTTPS.

7. Regular Security Testing:

Conduct periodic security assessments and vulnerability testing to identify and fix issues.

Conclusion

- API security is a critical aspect of modern application development, as APIs handle sensitive data and enable communication between systems.
- In this report, several common API security risks such as broken authentication, broken authorization, excessive data exposure, lack of input validation, and security misconfiguration were identified and analyzed.
- These vulnerabilities can lead to serious consequences including unauthorized access, data breaches, and system misuse if not properly addressed.
- By implementing strong security practices such as proper authentication, data protection, input validation, and secure configurations, organizations can significantly reduce the risk of API-related attacks.
- This project enhanced understanding of API security concepts and highlighted the importance of securing APIs in real-world applications.

Securing APIs is essential to ensure safe and reliable digital communication.